



Beego Vulnerable Web Application

Gebaseerd op OWASP Top 10:2025 | Versie 1.0 | Maart 2026

■■ **WAARSCHUWING:** BVWA is uitsluitend bedoeld voor educatieve doeleinden. Gebruik het **NOOIT** in productie of op een publiek toegankelijke server. Draai het uitsluitend in een geïsoleerde, lokale testomgeving.

Inhoudsopgave

1. Projectoverzicht
2. Installatie & Configuratie
3. Projectstructuur
4. OWASP Top 10:2025 Modules
5. Test Credentials
6. Technologieën
7. Disclaimer

1. Projectoverzicht

BVWA (Beego Vulnerable Web Application) is een opzettelijk kwetsbare webapplicatie gebouwd met het Go Beego framework. Het project is gebaseerd op de OWASP Top 10:2025 en biedt voor elke kwetsbaarheid zowel een kwetsbare als een veilige implementatie.

Doelgroep:

- Ontwikkelaars die beveiligingskwetsbaarheden willen begrijpen
- Security studenten en pentesters
- Teams die veilig coderen willen oefenen
- Docenten die beveiligingsonderwijs geven

Leerdoelen per module:

Elke OWASP-module bevat drie onderdelen:

Onderdeel	Beschrijving
Kwetsbare versie	Demonstreert de aanval in de praktijk
Veilige versie	Toont de correcte, veilige implementatie
Uitleg	Beschrijft de kwetsbaarheid en mitigatie

2. Installatie & Configuratie

Vereisten:

Tool	Versie	Website
Go	1.21 of hoger	golang.org
MySQL	5.7 of hoger	mysql.com
Beego	v2.x	beego.vip
bee CLI	v2.x	github.com/beego/bee

Installatiestappen:

Stap 1	Clone het project <code>git clone https://github.com/gebruiker/bvwa.git cd bvwa</code>
Stap 2	Installeer dependencies <code>go mod tidy</code>
Stap 3	Installeer bee CLI <code>go install github.com/beego/bee/v2@latest</code>
Stap 4	Maak de database aan <code>mysql -u root -p CREATE DATABASE bvwa;</code>
Stap 5	Configureer app.conf Zie configuratie hieronder
Stap 6	Start de applicatie <code>bee run</code>

Configuratie (conf/app.conf):

```
appname = bvwa
httpport = 8080
runmode = dev
sessionon = true
sessionname = bvwasession

# Database
db_user = root
db_pass = jouwwachtwoord
db_host = 127.0.0.1
```

```
db_port = 3306  
db_name = bvwa
```

3. Projectstructuur

```

bvwa/
├── conf/
│   └── app.conf
├── controllers/
│   ├── access_control.go (A01)
│   ├── security_misconfig.go (A02)
│   ├── supply_chain.go (A03)
│   ├── crypto.go (A04)
│   ├── injection.go (A05)
│   ├── insecure_design.go (A06)
│   ├── auth.go (A07)
│   ├── integrity.go (A08)
│   ├── logging.go (A09)
│   └── exceptions.go (A10)
├── routers/
│   └── router.go
├── views/
│   ├── home/index.tpl
│   ├── admin/dashboard.tpl
│   ├── misconfig/index.tpl
│   ├── supplychain/index.tpl
│   ├── crypto/index.tpl
│   ├── injection/sql.tpl
│   ├── injection/xss.tpl
│   ├── design/index.tpl
│   ├── auth/login.tpl
│   ├── integrity/index.tpl
│   ├── logging/index.tpl
│   └── exceptions/index.tpl
├── main.go
├── go.mod
└── README.md
```

4. OWASP Top 10:2025 Modules

A01 Broken Access Control

Beschrijving:	Toegangscontrole wordt niet correct afgedwongen. Gebruikers kunnen buiten hun bedoelde rechten handelen.
Routes:	/admin/vulnerable /admin/secure
Mitigatie:	Rolgebaseerde sessiecontrole, vernieuw sessie-ID na login

A02 Security Misconfiguration

Beschrijving:	Ontbrekende of verkeerde security headers zoals X-Frame-Options, CSP en HSTS.
Routes:	/misconfig/vulnerable /misconfig/secure
Mitigatie:	Voeg alle security headers toe in elke response

A03 Software Supply Chain Failures

Beschrijving:	Gebruik van verouderde of kwetsbare dependencies (MD5 vs SHA-256).
Routes:	/supplychain/vulnerable /supplychain/secure
Mitigatie:	Gebruik go mod verify, update dependencies regelmatig

A04 Cryptographic Failures

Beschrijving:	Zwakke versleuteling van gevoelige data, gebruik van MD5/SHA1 voor wachtwoorden.
Routes:	/crypto/vulnerable /crypto/secure
Mitigatie:	Gebruik bcrypt voor wachtwoorden, SHA-256 voor integriteit

A05 Injection (SQL & XSS)

Beschrijving:	Ongesaneerde gebruikersinput wordt als SQL-commando of HTML/JS uitgevoerd.
----------------------	--

Routes:	/injection/sql/vulnerable /injection/xss/vulnerable /injection/sql/secure /injection/xss/secure
Mitigatie:	Gebruik geparametriseerde queries, escape output in templates

A06 Insecure Design	
Beschrijving:	Ontwerpfouten zoals wachtwoord reset zonder rate limiting of token-verificatie.
Routes:	/design/vulnerable /design/secure
Mitigatie:	Implementeer rate limiting, gebruik token-gebaseerde resets

A07 Authentication Failures	
Beschrijving:	Zwakke login: geen rate limiting, plaintext wachtwoorden, slechte sessiebeheer.
Routes:	/auth/vulnerable /auth/secure
Mitigatie:	bcrypt, rate limiting per IP, sessie vernietigen na login

A08 Software/Data Integrity Failures	
Beschrijving:	Geserialiseerde data wordt zonder integriteitscontrole geaccepteerd — manipulatie mogelijk.
Routes:	/integrity/vulnerable /integrity/secure
Mitigatie:	Gebruik HMAC-SHA256 handtekeningen op geserialiseerde data

A09 Security Logging & Alerting Failures	
Beschrijving:	Beveiligingsgebeurtenissen worden niet gelogd, aanvallen blijven onopgemerkt.
Routes:	/logging/vulnerable /logging/secure
Mitigatie:	Log alle auth-events, alert bij >3 mislukte pogingen

A10 Mishandling of Exceptional Conditions	
---	--

Beschrijving:	Fouten worden genegeerd of lekken interne details; fail-open gedrag verleent ongewenst toegang.
Routes:	/exceptions/vulnerable /exceptions/secure
Mitigatie:	Fail-closed principe, generieke foutmeldingen, interne logging

5. Test Credentials

Gebruikersnaam	Wachtwoord	Rol
admin	password123	Administrator
user	user123	Gebruiker

■■ Deze credentials zijn uitsluitend voor testdoeleinden. Gebruik ze nooit in een productieomgeving.

6. Technologieën

Technologie	Versie	Gebruik
Go	1.21+	Programmeertaal
Beego	v2.x	Web framework (MVC)
MySQL	5.7+	Database
bcrypt	golang.org/x/crypto	Wachtwoord hashing
HMAC-SHA256	crypto/hmac	Data integriteit
bee CLI	v2.x	Development tool

7. Disclaimer

BVWA is een educatief project. Het is opzettelijk kwetsbaar gebouwd om beveiligingsconcepten te demonstreren. Het gebruik van BVWA buiten een geïsoleerde testomgeving is uitdrukkelijk verboden. De auteurs aanvaarden geen enkele verantwoordelijkheid voor schade of misbruik voortvloeiend uit dit project. Gebruik altijd verantwoord en ethisch — uitsluitend op systemen waarvoor je toestemming hebt.